

前沿技术专题研究报告

人工智能安全平台 (AISP / AI TRiSM)

储备库层级：论证层（系统论证） | 编制：科技规划处 | 日期：2026年8月17日（v2.1深化：技术背景与架构章节拆分充实）

一、执行摘要

人工智能安全平台（AISP，Gartner称AI TRiSM）是AI监管趋严与智能体规模化落地共同倒逼出的“必答题”，而非可选项。威胁侧，Gartner已将提示注入与深度伪造并列为2026年安全负责人须紧急改进的头部威胁[1,2]；市场侧，2024—2025年间五起标志性并购（Palo Alto Networks收购Protect AI、Cisco收购Robust Intelligence、Check Point收购Lakera、F5收购Calypso AI、SentinelOne收购Prompt Security，披露交易总额超15亿美元）显示AI安全正从“点工具”快速整合进主流网络安全平台[8-13]，全球AI TRiSM市场规模预计从2025年29.1亿美元增至2034年173亿美元，年复合增长率21.92%[14]；治理侧，影子AI（未经审批的AI工具使用）已是企业AI风险的最大单一来源之一——78%的职场AI用户使用未经IT批准的工具，40%的组织在2024年经历过AI相关安全事件，缺乏治理的组织事故修复成本是有治理组织的2.5倍[15]。

同业实践方面，新加坡银行公会（ABS）联合DBS、OCBC、UOB等10家银行及新加坡金融管理局（MAS）于2025年5月发布《生成式AI护栏手册》，沉淀出覆盖30余个真实用例、9类护栏、14类风险的行业级方法论[18]；DBS单一机构已部署超1500个AI模型、覆盖370个业务场景，通过统一治理框架将AI项目从立项到上线的周期从15个月压缩到不足3个月[19]。国内方面，2026年已有53.5%的银行落地大模型应用（较2025年的39.0%显著提升），32.3%的银行进入智能体试点阶段[20]，但安全治理能力的建设速度普遍滞后于应用落地速度，这正是AISP论证的窗口期所在。

核心判断：AISP是本行001智能体、002 AI原生应用架构、017智能体互操作协议规模化落地的前置护栏，具有强制属性（监管与风险倒逼）而非单纯效率工具属性。建议维持“论证层”定档，以AI资产台账与试点场景护栏POC作为先行动作即刻启动，论证阶段与001智能体治理合并立项，用6—9个月完成能力缺口评估、双路径POC与AISP能力蓝图，形成本行AI安全的统一护栏底座。

二、立项说明与研究方法

人工智能安全平台（AISP）指覆盖AI可信、风险与安全管理的框架与工程能力：提示注入防护、数据与输出护栏、模型评估、运行时异常检测与AI治理平台。其思想源头是Gartner提出的AI信任、风险与安全管理框架（AI TRiSM），核心主张是把AI安全从“上线后补救”前移为“开发即内嵌、运行时强制”。本条目为Gartner分析师2026年推荐新增（018号），是本行001智能体、002 AI原生架构与017互操作协议规模化落地的前置护栏。

本报告为深化研究，在原v1.2基础上新增三方面研究方法：一是同业案例检索，覆盖国际（新加坡银行公会/DBS）与国内（银行业大模型应用跟踪报告）两条线，要求案例可追溯信源、量化数据不臆造；二是厂商格局调研，对AI安全/AI TRiSM赛道代表厂商的定位、融资与并购动态做实名梳理；三是监管条款映射，将原有概括性表述落实到具体文件与条款。研究方法引用规范同ZT001，原有信息采集截至2026年7月8日，本次深化信息采集截至2026年8月17日。

三、技术背景与基本原理

3.1 问题背景：为什么会出现AISP

在生成式AI与智能体进入生产环境之前，安全能力建设依赖两条相对独立的路径：一条是传统应用/API安全（WAF、API网关、DLP数据防泄漏、IAM身份与访问管理），另一条是传统模型风险管理（面向信贷评分、反欺诈等判别式模型的周期性验证、回溯测试与上线审批）。这两条路径在大模型与智能体场景下同时暴露出结构性缺陷，是AISP作为独立技术品类出现的根本原因。

传统应用安全的缺陷在于防护对象从“确定性代码”变成了“概率性语言行为”：WAF、传统DLP等工具的检测逻辑建立在规则/签名匹配之上（正则表达式、已知恶意指纹黑名单、结构化协议的语法校验），这一逻辑成立的前提是攻击面是有限且可枚举的（如SQL注入的语法模式）。但提示注入攻击是用自然语言表达的，攻击语句在语法上与正常业务指令没有本质区别，同一攻击意图可以用近乎无限种自然语言表述实现（同义改写、多语言混合、角色扮演包装等），固定规则库无法穷举，这直接导致传统安全网关对提示注入“看不懂也拦不住”。

传统DLP的缺陷在于只能识别“复制”出来的泄露、无法识别“生成”出来的泄露：传统DLP基于关键词/正则/指纹比对，擅长拦截结构化敏感信息（身份证号、卡号）的直接外传，但大模型的信息泄露常常是“重新组织和生成”出来的——例如把训练数据或上下文中的片段信息用改写后的语言表达出来，或在多轮对话中被诱导拼凑出完整的敏感信息，这类泄露不经过任何“复制粘贴”动作，传统DLP的指纹比对机制天然检测不到。

传统模型风险管理的缺陷在于验证方式是周期性的，而大模型的行为是持续变化的：判别式模型（如信贷评分卡）一旦上线，在给定输入下的输出是确定且稳定的，因此可以用“上线前一次性验证+定期回溯”的方式管控风险。但生成式模型的实际行为高度依赖提示词模板、上下文窗口内容、检索增强（RAG）知识库的实时更新，同一模型在不同提示词版本、不同知识库快照下可能表现出完全不同的行为，静态的时间点式验证无法覆盖这种持续漂移，必须转为运行时的持续检查与强制执行——这正是Gartner提出AI TRiSM框架时反复强调“运行时检查与强制执行”而非“一次性上线审批”的原因[1,4]。

传统身份与访问管理的缺陷在于管得住“谁能访问”，管不住“AI做的事是否合理”：零信任/IAM体系解决的是资源级、身份级的访问控制问题（这个账号能不能调用这个接口），但智能体获得授权后，其自主决策产生的具体动作（调用哪个工具、生成什么指令、是否偏离原始任务目标）是语义层面的问题，传统IAM在动作发生之前无法判断这个动作本身是否安全合理——这也是本报告4.3节将“智能体身份治理”列为AISP与零信任交叠区、而非零信任可独立覆盖的原因。

四类缺陷共同指向同一个结论：AI引入的攻击面和风险类型是既有安全体系的能力盲区，而不是既有工具“再加强一点”就能覆盖的量变问题，这正是AISP/AI TRiSM作为独立技术品类被提出并快速产业化的根本驱动力。

3.2 核心定义与概念界定

AI安全平台（AISP）是覆盖AI可信、风险与安全管理的框架与工程能力集合，具体包括提示注入防护、数据与输出护栏、模型评估、运行时异常检测与AI治理平台五类能力[1,4]（能力细分见4.2节）。其方法论源头是Gartner提出的AI信任、风险与安全管理框架（AI TRiSM, AI Trust, Risk and Security Management），核心组件是运行时检查与强制执行——作用于模型、应用与智能体交互，保证每笔交互与组织治理策略对齐[1,4]。

从构成要素看，“AI安全”这一概念至少包含三个必要维度，缺一不可：可信（Trust）——模型输出是否可靠、无害、符合预期（对应输出护栏与幻觉检测）；风险（Risk）——模型/智能体行为是否可能造成业务或合规损失（对应模型评估与红队）；安全（Security）——模型/智能体是否可能被外部攻击操纵或成为攻击入口（对应输入防护与运行时

监测)。三者共同构成AISP区别于单点工具(如仅做内容过滤的敏感词库)的完整边界,单独具备任一维度的能力都不能称为AISP。

需要说明的是, AI安全治理的另一条重要参照线是NIST《人工智能风险管理框架》(AI RMF), 其提出的"可信AI"特征(有效可靠、安全、稳健、可问责透明、可解释、隐私增强、公平)与AI TRISM在治理目标上高度一致, 二者常被作为互补参照使用; 此处NIST AI RMF的表述为背景性行业共识, 非本报告本轮WebFetch定向核实的信源, 如需正式引用建议后续单独核实原文后补入参考文献。

3.3 技术原理与关键机制

AISP并非单一技术, 而是五类机制的组合, 各自解决不同环节的问题:

输入侧检测机制(提示注入/越狱防护): 主流技术路线有两类。一是分类器式检测, 用专门训练的小模型(而非规则库)对输入提示做语义分类, 判断是否包含注入意图、越狱模式或恶意载荷, 其优势是能识别规则库无法穷举的自然语言变体, 代价是存在误报/漏报, 且需要持续用新出现的攻击样本重新训练或微调; 二是架构级隔离, 即"双模型/权限分离"模式——用一个具备完整权限的"特权模型"处理可信指令, 用另一个仅能读取、不能执行敏感操作的"隔离模型"处理外部/不可信内容(如网页抓取结果、用户上传文档), 从架构上切断"外部内容能直接操纵特权模型行为"的路径, 而不是单纯依赖分类器判断准确率。开源护栏系统LlamaFirewall即采用模块化扫描器架构, 将提示注入检测、思维链对齐监测(检测模型是否偏离原始任务目标)、生成代码静态安全扫描等能力拆分为可独立启用的组件, 供开发者按场景组合[7]。

输出侧检测机制(护栏/幻觉防护): 敏感信息泄露拦截通常采用命名实体识别(NER)与模式匹配的组合, 对生成内容做二次扫描; 内容合规过滤依赖专门的有害内容分类模型; 幻觉与引用校验则相对更复杂, 主流做法包括"生成内容与检索证据的一致性核验"(检查模型输出是否能在RAG检索到的原文中找到依据, 找不到依据的表述标记为潜在幻觉)以及"自一致性校验"(对同一问题让模型生成多次输出并比较差异, 差异过大则判定为低置信度回答需人工复核)。

运行时监测机制(行为异常检测与强制执行): 这是AI TRISM区别于零散安全工具的关键增量[1,4], 技术上依赖对智能体的工具调用序列、访问的数据范围、动作频率建立行为基线, 通过持续监测偏离基线的异常模式(如短时间内异常高频调用某个高权限工具、访问了任务目标之外的数据范围)触发告警或自动阻断; 这类机制本质上借鉴了传统IT安全中UEBA(用户与实体行为分析)的思路, 区别在于监测对象从"人类用户的操作序列"变成了"智能体的决策与动作序列"。

模型评估与红队机制: 上线前安全测试通过构造对抗性提示词集合(覆盖已知攻击模式与新型变体)批量测试模型的抗攻击表现, 形成量化的安全通过率指标; 红队演练则是人工/自动化结合地主动模拟攻击者视角发现系统性漏洞, 通常依据标准化风险分类体系(如OWASP智能体十大风险ASI01-10[16])设计攻击场景, 确保覆盖面而非零散测试。

治理层机制: 技术上主要是AI资产台账(通过扫描API调用流量、网络出口记录发现组织内实际在被使用的AI工具与模型, 类似CASB云访问安全代理对影子IT的发现逻辑, 用于发现"影子AI")、策略管理(将护栏规则、风险分级标准以可配置策略的形式集中管理, 而非分散在各业务系统中硬编码)与审计取证(对模型输入输出、护栏拦截/放行决策做留痕, 满足第六章监管映射中的可审计要求)。

3.4 与既有范式的本质区别

把"旧方式 vs 新技术"逐维度对比, 让"新在哪里"一目了然:

维度	传统应用/内容安全范式	AI原生安全范式（AISP）
防护对象	确定性代码逻辑与已知攻击签名	概率性模型行为与语义级攻击意图
检测方式	规则/签名匹配（正则表达式、关键词黑名单、协议语法校验）	语义分类模型 + 行为基线组合检测，需持续学习新攻击变体
响应与更新节奏	人工维护规则库，更新滞后于新攻击手法出现	护栏本身需要持续红队验证与再训练，属于持续对抗过程而非一次性建设
可扩展性	单点部署（WAF/DLP网关），与具体业务场景耦合度低、可独立运行	需跨模型/跨智能体统一策略与数据口径，扩展性依赖治理层的成熟度
成本结构	一次性建设投入为主，后续为低频规则维护	建设 + 持续运营并重，红队与策略迭代是长期投入项，非一次性投入
适用边界	结构化协议、确定性接口（HTTP请求语法、SQL查询、已知文件格式）	自然语言/多模态非结构化交互，以及智能体的自主决策与动作

3.5 技术演进脉络

- 2023年：NIST发布《人工智能风险管理框架》（AI RMF 1.0），同年Gartner在年度技术趋势展望中提出"AI TRiSM"概念，二者通常被视为"AI安全与治理"从模型风险管理中独立出来成为专门学科的起点（此条为行业公开背景知识，非本报告本轮WebFetch定向核实来源，正式引用前建议单独核实原文）。
- 2024年3月：全国网络安全标准化技术委员会发布TC260-003《生成式人工智能服务安全基本要求》，是国内第一批将模型安全、语料安全、标注安全、措施安全系统化提出具体量化指标的规范性文件[17]。
- 2024年8月：Cisco宣布收购Robust Intelligence，是近13个月内AI安全赛道五起标志性并购的开端，标志独立AI安全初创公司开始被主流网络安全厂商整合[10]。
- 2025年5月：新加坡银行公会（ABS）联合10家银行及MAS发布《生成式AI护栏手册》，是银行业首个覆盖30余个真实场景、系统化沉淀护栏方法论的行业级文件，标志AISP方法论从"厂商框架"走向"行业最佳实践汇编"[18]。
- 2025年5月：LlamaFirewall开源护栏系统对应论文发布，标志核心护栏能力开始从厂商专有产品走向可复用、可拆解的开源组件[7]。
- 2025年7—9月：Palo Alto Networks收购Protect AI、Check Point拟收购Lakera、F5收购CalypsoAI、SentinelOne收购Prompt Security密集发生，独立AI安全品类加速并入综合网络安全平台厂商能力矩阵[9,11,12,13]。
- 2026年：OWASP正式发布《Top 10 for Agentic Applications》，风险分类范围从"模型输出安全"扩展到"智能体自主决策与动作安全"[16]；同年6月Gartner将提示注入与深度伪造列入年度头部威胁，明确要求安全负责人紧急改进[1]。

从这条脉络看，AISP正处于"方法论已相对成熟、独立厂商快速被整合、监管要求陆续明确"的产业化中期阶段，尚未进入技术定型期（详见3.6节局限与4.2节能力构成）。

3.6 当前技术局限与未解问题

- 语义检测的鲁棒性不足：分类器式护栏对未见过的攻击变体（同义改写、多语言混合、编码混淆等）泛化能力有限，误报与漏报并存，需要持续红队测试才能维持有效性，这一挑战在LlamaFirewall等护栏系统的设计中已被明确列

为核心难点之一[7]。

- 运行时监测缺乏统一行为基线标准：多智能体协作场景下"正常行为"的边界难以预先定义，自由度越高的场景异常检测越容易失效或产生大量误报，这也是本报告9.2节将"多智能体治理工具"列为"业界尚不成熟、暂以跟踪为主"能力项的技术层面原因。
- 红队评测缺乏标准化基准：不同厂商、不同研究采用的攻击分类体系与评分方法尚未统一，跨产品的安全能力难以直接比较，这也是9.2节将"AI红队常态化机制"列为高价值、中高难度能力项的原因之一。
- 护栏决策的可解释性不足：多数商用护栏以分类器形式运行，对于具体某一次交互"为何被拦截/为何被放行"往往缺乏可审计的解释链条，这与第六章监管映射中TC260、EU AI Act对可解释、可审计的要求之间存在现实张力，需要治理层的审计留痕机制加以弥补而非护栏本身自动具备。
- 安全强度与响应性能的权衡尚无成熟工程方案：护栏检测环节会引入额外的推理延迟，在高并发、低延迟敏感的场景（如实时客服交互）中，如何在不明显影响用户体验的前提下维持足够的检测强度，目前仍主要依赖场景化的工程取舍，缺乏行业公认的最佳实践基准。

四、技术架构与生态定位

4.1 生态位/产业链图谱

AISP在本行AI技术栈中处于"承上启下"的护栏层位置，可分四层看待其生态位：上游是基础模型层（自建或外部大模型/API），中游分两条并行支路——智能体与应用编排层（对应001智能体、002 AI原生架构、017互操作协议、034多智能体系统）与可观测/评估底座（对应036 LLMOps，二者共用埋点与评估数据，AISP消费其观测数据实施安全策略强制）；AISP本身位于中游之上、下游业务系统之前，承担"每一次模型/智能体调用是否放行"的强制执行点；下游是业务系统与终端用户。这一生态位决定了AISP不是一个孤立可选模块，而是任何一条AI应用链路要规模化上线都必须经过的关口——这也是本报告将其定位为"强制性护栏"而非"效率增强型"技术的依据（呼应3.1节问题背景与执行摘要的紧迫度判断）。

图1 AISP在本行AI技术栈中的生态位示意（自制示意图）

4.2 能力构成/技术架构分层

落地视角下AISP可拆为五层，与3.3节的技术机制一一对应，但视角不同——3.3节讲"每层内部怎么运作"，本节讲"五层如何组织成一个整体架构"：

- 输入防护层：提示注入检测、越狱识别、恶意内容过滤（技术机制见3.3"输入侧检测机制"）。
- 输出护栏层：敏感信息泄露拦截、内容合规过滤、幻觉与引用校验（技术机制见3.3"输出侧检测机制"）。
- 模型评估层：上线前安全测试、红队演练、对抗样本评测——与036号LLMOps的评估层交叠，AISP侧重安全性、LLMOps侧重质量（技术机制见3.3"模型评估与红队机制"）。
- 运行时监测层：行为异常、越权调用、数据外流的实时检测与阻断，是AISP区别于零散安全工具的关键增量层（技术机制见3.3"运行时监测机制"）。
- 治理层：AI资产台账、策略管理、审计取证，是五层中承接第六章监管映射与第九章效益测算的落地基础（技术机制见3.3"治理层机制"）。

五层能力并非同等成熟——输入输出护栏已是行业标配起点，运行时监测与治理层的系统化程度才是真正拉开同业差距的环节（详见第七章同业案例小结）。

图2 AISP能力构成五层模型（自制示意图）

4.3 与相邻/易混淆技术的边界

三组边界需要厘清，避免概念混用或重复投入：

- 与008零信任的边界：零信任解决"谁能访问什么"的身份与资源级问题，AISP解决"AI行为本身是否安全"的语义与动作级问题；智能体身份治理是两者的交叠区，需要零信任提供身份基础设施、AISP提供行为语义层判断。
- 与036号LLMOps的边界：评估与观测基础设施可由两者共用（同一套埋点与观测数据），但目标不同——LLMOps关注模型输出质量、成本、延迟等运营指标，AISP消费同一份观测数据实施安全策略强制，二者是"共用底座、不同消费目的"的关系，不是重复建设。
- 与001智能体治理的边界：OWASP智能体十大风险（ASI01-10）是威胁分类标准，AISP是承接这些威胁缓解措施的平台化载体——智能体控制台中呈现的安全功能，其底层能力即由AISP五层架构提供，两者是"标准与实现"的关系而非并列的两套体系。

五、威胁态势与产业成熟度研判

5.1 威胁升级：提示注入列入顶级威胁

Gartner在2026年6月发布的网络安全四大关键威胁中，将提示注入与深度伪造并列为需要安全负责人紧急改进的方向：针对大模型的提示注入攻击操纵AI行为以泄露敏感信息或执行未授权动作，建议的应对为AI安全测试前置、强系统提示与AI运行时护栏三件套[1,2]。OWASP于2026年发布的《Top 10 for Agentic Applications》进一步把智能体场景的风险类型标准化为十类（详见附录11.1），其中目标劫持（ASI01）、工具滥用（ASI02）、记忆与上下文投毒（ASI06）与本行001智能体试点场景直接相关[16]。评估表初判引用的Gartner预警同样成立：到2026年至少80%的未授权AI操作将源于内部策略违规而非外部攻击——这意味着AISP的首要对手是"内部影子AI与越权使用"，治理属性强于对抗属性，这一判断在5.3节的影子AI数据中得到进一步印证。

5.2 市场格局与代表厂商图谱

AISP/AI TRiSM市场正处于"点工具快速整合进平台"的关键窗口期。2024年8月至2025年9月的十三个月内，主流网络安全厂商密集并购AI安全初创企业，形成清晰的整合浪潮：

收购方	标的	时间	金额	标的定位
Cisco	Robust Intelligence	2024-08	约4亿美元	AI模型安全测试与运行时防护，2024年Gartner AI安全Cool Vendor[10]
Palo Alto Networks	Protect AI	2025-07	约6.5—7亿美元（据报道，未正式披露）	AI模型/供应链安全扫描与治理[9]
Check Point	Lakera	2025 Q4（拟）	3亿美元	苏黎世AI原生安全平台，红队评估(Lakera Red)+运行时防护(Lakera Guard)[11]
F5	CalypsoAI	2025-09	未披露	AI护栏与红队测试，已整合为"AI Guardrails"与"AI Red Team"产品线[12]
SentinelOne	Prompt Security	2025年	2.5亿美元	企业GenAI使用可见性、数据泄露防护、策略执行[13]

这一轮整合共同指向一个判断：AISP不会长期以独立品类存在，而是快速并入综合安全平台厂商的能力矩阵——这与036号LLMOps市场格局的演化路径一致，对本行选型的启示是优先评估"能力"而非"独立品牌"，并对已被收购标的的产品路线图延续性保持关注。仍以独立公司形态活跃、值得持续跟踪的厂商包括HiddenLayer（2025年Gartner AI TRiSM市场指南代表厂商，覆盖模型扫描、威胁检测、自动化红队全生命周期[8]）、Noma Security（AI资产清点与治理工作流）、Mindgard（AI红队与安全测试自动化）、Patronus AI（输出评分与幻觉测试）等。Gartner在AI TRiSM市场指南中判断市场演化呈四个方向：安全能力嵌入创新团队工作流、统一运行时检查与强制执行、基础设施提供商扩展AI安全服务、行业整合仍在持续[8]。

全球AI TRiSM市场规模预计从2025年29.1亿美元增长至2026年35.4亿美元，到2034年达173亿美元，预测期年复合增长率21.92%；当前北美是最大市场，欧洲与亚太地区预计增速最快[14]。市场高速增长与厂商快速整合并存，进一步支持"论证先行、选型宜组件化可替换"的既有判断。

5.3 影子AI：治理紧迫性的量化依据

多项行业调研显示，影子AI（未经审批使用的AI工具）是当前企业AI风险中最紧迫、也最容易被低估的一类：78%的职场AI用户使用未经IT批准的自带AI工具，65%的员工使用未获批准的AI工具完成工作，33%的员工定期用个人账户在公司设备上访问AI工具，且250%是2023年第一季度到2024年第一季度影子AI使用的增长率[15]。数据泄露风险同样突出：27%的企业员工曾向公开AI工具输入机密公司数据，15%的员工定期将客户数据输入未授权AI工具，2023—2024年间共享给AI工具的数据量增长485%[15]。治理现状则明显滞后：60%的安全团队缺乏对员工所用AI工具的可见性，52%的组织没有正式的外部AI工具使用政策，仅34%的组织建立了正式的影子AI检测项目[15]。财务影响上，2024年数据泄露平均成本达488万美元，40%的组织在2024年经历过AI相关安全事件，且治理缺失的组织事故修复成本是有治理组织的2.5倍[15]。这组数据为本报告"AI资产台账与影子AI发现"列为能力建设优先级第一项（见9.2）提供了直接的量化支撑。

5.4 技术选型比选：自建、外采与混合路径

路径	优势	局限	适配场景	成本量级参考
自建（基于开源组件，如LlamaFirewall等护栏框架）	可控性强、数据不出行、可深度定制内部策略	需要专职AI安全工程能力，运行时监测与红队工具链需自行搭建整合	标准化程度高的输入输出护栏，或数据出境高度敏感的场景	人力投入为主，2—3人团队起步，工具链多为开源免许可费
外采（专业AISP产品或安全大厂AI安全模块）	交付速度快、跟随厂商能力迭代、有现成的威胁情报与红队方法论	存在厂商锁定与数据外送合规审查成本；本轮并购潮下产品路线图存在不确定性	运行时监测、自动化红队等技术门槛高、迭代快的能力	许可费+实施费，通常与调用量/席位挂钩，需结合国产化适配要求评估
混合（治理层自建+执行层选择性外采，本报告建议路径）	兼顾数据可控与交付速度，治理标准统一、执行组件可替换	需要清晰的接口标准与厂商退出机制设计，架构复杂度较高	治理层自建保证可控与合规留痕，护栏与红队工具优先外采成熟组件加速上线	治理层人力投入、执行层许可费投入并行

结合5.2节的市场整合趋势与5.3节的影子AI紧迫性，本报告倾向"混合路径"：治理层（AI资产台账、策略管理、审计取证）作为组织能力沉淀点应自建，执行层（护栏、红队）可优先外采成熟组件以缩短上线周期，待能力成熟后再评估自建替代的必要性。

六、监管与合规映射

AISP是AI监管要求的安全侧承接层，具体映射关系如下：

监管依据（具体文件/条款）	对应AISP能力	我行现状与差距
TC260-003-2024《生成式人工智能服务安全基本要求》模型安全要求：覆盖31类安全风险，需构建≥2000条人工测试集，生成内容安全通过率须≥90%，并维护敏感词/关键词黑名单[17]	输出护栏层（内容合规过滤）、模型评估层（上线前安全测试）	各行大模型平台普遍已内置基础内容过滤以满足备案要求，差距主要在测试集规模与通过率的持续验证机制
TC260-003语料安全要求：需记录每个语料源的来源链路（版权/授权/用户同意），随机抽样4000条语料的违法不良信息比例不得超过5%[17]	治理层（AI资产台账对语料来源的留痕）	语料合规更多落在训练/微调环节，AISP需覆盖运行时“哪些场景使用了哪些数据源”的留痕，与训练侧台账需衔接
TC260-003措施安全要求：用户实名制、违法内容处置机制、投诉举报响应与应急预案[17]	治理层（策略管理、审计取证）、运行时监测层	传统IT安全体系已覆盖应急响应机制，差距在于是否已扩展覆盖AI特有场景（如提示注入导致的异常输出）
中国人民银行对AI应用可解释、可审计、可控的导向（见ZT001第四章）	治理层（决策留痕、审计取证）	与033号决策智能平台DIP治理层要求高度重叠，两条目治理层建设应统筹推进
欧盟AI法案（EU AI Act）高风险系统的日志、人类监督与稳健性要求（境外机构/跨境业务适用）	运行时监测层（日志留存）、治理层（人工在场机制HITL）	境内业务暂不直接适用，其“分级风险—分级管控”思路可借鉴（见7.1新加坡银行公会框架）
OWASP《Top 10 for Agentic Applications 2026》十类风险(ASI01-10)，行业事实基线[16]	五层能力均有对应，尤其ASI01目标劫持、ASI02工具滥用、ASI06记忆投毒对应输入防护层与运行时监测层	已在ZT001中定为红队基线，当前尚无覆盖全部十类风险的系统化红队机制

特别地，反向约束同样明确：决策/输出自动化的每一步扩权都应有测试证据与回退机制支撑，AISP的分级防护能力应显式映射到行内数据分级与业务权限体系，而非一刀切设置统一护栏强度。

七、同业实践与案例研究

7.1 新加坡银行业集体护栏框架：ABS《生成式AI护栏手册》

新加坡银行公会（ABS）联合星展银行（DBS）、华侨银行（OCBC）、大华银行（UOB）等10家主要银行机构及新加坡金融管理局（MAS），于2025年5月发布《生成式AI护栏手册》，是目前公开可查、由银行业集体沉淀的最系统化AISP方法论之一[18]。手册基于超过30个真实业务场景，覆盖文件提取/摘要、代码生成、客户服务等7大应用类别，系统梳理了14类关键风险（含幻觉/编造、模型准确性不足、有毒/冒犯性输出、代表性偏见、治理缺失、人工监督不足等）及对应的9类护栏。护栏分三层：企业级护栏（治理结构、员工培训、风险管理）、系统级技术护栏（输入输出过滤、自定义模型微调、红队测试、提示词工程）、系统级流程护栏（监控验证、人工在环审核HITL、用户反馈迭代、透明度与知情同意）。手册明确提出“风险分级方法”：高风险应用场景（如面向客户的投资建议）需要更复杂的护栏组合（如模型定制化+强制人工复核），低风险场景（如内部知识检索）可采用轻量级控制，这一思路与本行5.4节“混合路径”的选型逻辑一致，可直接作为本行护栏分级标准设计的参照模板。

7.2 单一机构深度案例：DBS银行的治理框架与量化成效

DBS银行采用"PURE原则"（Purposeful目的明确、Unsurprising行为可预期、Respectful尊重用户、Explainable可解释）作为AI治理的核心框架，由高级别委员会统筹AI用例的合规性与伦理审查，并采取"co-pilot approach"确保关键决策"始终有人在环"[19]。其治理体系由平台、流程、人员三部分构成：平台上建立集中式数据平台与AI能力协议库；流程上建立覆盖偏差风险与隐私保护的治理框架；人员上投入全员AI素养培训。量化成效方面，DBS已部署超过1500个AI模型、覆盖370个业务场景，通过统一的治理与协议复用机制，将AI项目从立项到上线的周期从15个月压缩至不足3个月，预计到2025年为银行创造10亿新加坡元的经济价值[19]。这一案例的可借鉴之处在于：治理框架不是上线速度的对立面，统一的护栏与能力复用底座（对应本报告4.2节能力构成中的治理层）反而是规模化提速的前提——这为本行"治理层先行"的路径选择提供了直接的同业证据。

7.3 国内银行业实践：应用先行、治理待补的普遍格局

据2026年发布的《中国银行业大模型应用跟踪报告》，2026年已有53.5%的银行落地大模型应用（较2025年的39.0%明显提升），32.3%的银行正在采用智能体应用，超九成银行已进入采用或规划阶段[20]。报告梳理的典型案例包括工商银行（财富助手智能体、测试智能体实践）、招商银行（编码智能体实践）、交通银行（智能运维大模型实践）等国内头部银行，以及富国银行、花旗银行、瑞银集团等海外机构的智能体应用[20]。报告同时指出大模型面临的主要风险包括准确性问题/幻觉、系统性偏见、隐私与安全风险、法律与伦理风险、信息泄露风险，并提出以定制化评估框架与完善安全护栏作为幻觉风险的核心应对策略之一[20]。需要说明的是，公开信源中当前应用案例的披露重点集中在业务效率与场景创新，对应用背后的AI安全治理机制（护栏配置、红队机制、影子AI管控）的具体做法披露较少，这与5.3节"应用先行、治理滞后"的判断相互印证，也说明国内同业在AISP能力建设上整体处于早期阶段，本行若能在护栏与治理层率先建成体系化能力，具有形成相对优势的窗口。

另需说明：行业内已出现面向金融场景的AI智能体红队测试方法论文（如基于OWASP ASI 2026框架、以虚构"财富管理智能体"为对象设计的目标劫持、工具滥用、记忆投毒三类攻防案例[21]），这类文章目前仍以方法论演示为主、未见披露真实机构的实测数据，可作为本行9.1节红队试点设计的方法参考，但不构成可引用的同业量化案例。

7.4 同业实践小结

三层实践共同指向一个结论：护栏能力（尤其输入输出过滤）已是行业标配起点，真正拉开差距的是治理层的系统化程度（AI资产台账、统一策略、量化风险分级）与红队机制的常态化程度。本行的论证重点应放在"运行时监测与治理层"这一多数同业尚未做透的环节，而非重复建设已成标配的基础护栏。

八、影响分析

8.1 机遇与价值

其一，智能体规模化的安全前提——001号试点的治理规范（熔断、审计、权限）需要AISP平台承载，否则治理停留在制度层面；其二，合规确定性——AI监管趋严方向明确，AISP投入具有强制性属性，先建者从容、后建者被动；其三，影子AI治理——80%未授权操作源于内部违规的预警意味着AI资产台账与使用监测有立竿见影的风险收敛价值，5.3节数据显示无治理组织的事故修复成本是有治理组织的2.5倍；其四，能力复用——护栏与评估能力横向服务全部AI条目（001/002/016/017/034/036），单位投入的覆盖面大；其五，同业验证的提速效应——DBS案例（7.2）显示统一治理框架反而能将AI上线周期压缩超80%，护栏建设与业务提速并非对立关系。

8.2 风险与挑战

风险项	概率	影响	触发场景	应对措施	责任环节
品类未收敛、厂商快速被并购	高（近13月5起收购[9-13]）	中	采购专业AISP产品后原厂商被并购整合	选型组件化、可替换，合同条款明确路线图变更退出机制	科技规划处（选型）、采购合规
护栏误拦截影响业务可用性	中	中	输入输出护栏策略设置过严	按场景风险分级设置护栏强度（参照7.1分级方法），建立人工复核快速通道	业务与科技条线联合调优
影子AI与内部违规使用	高（78%员工存在未批准使用[15]）	高	员工用未经审批的公开AI工具处理敏感数据	AI资产台账+运行时发现机制作为先行动作（9.2第一项）	安全条线牵头、科技条线建平台
多智能体治理工具不成熟	中	中	多智能体协作场景的身份与通信安全	现阶段以跟踪为主，服务034号，不作为本轮论证重点	科技规划处跟踪评估
组织协同断层	中	高	安全、科技、模型风险管理三条线职责边界不清	论证阶段即明确三方分工方案（见9.4）	科技规划处统筹提请行级明确
治理层建设滞后于应用扩张	中高（国内53.5%银行已落地[20]）	高	智能体试点场景快速增加，治理层建设未同步跟上	治理层先行（5.4混合路径），与001治理合并立项	科技规划处统筹

8.3 雷达四维评级复核

评估维度	评级	复核依据（2026-08）
技术成熟度	中	TRiSM框架清晰、护栏工具成形、Gartner市场指南发布，但2024-2025年密集并购显示品类仍在整合期
与本行契合度	高	AI×安全双命中；001/002/017规模化的前置刚需；同业（DBS、新加坡银行公会）已验证治理框架与上线提速可兼得
潜在业务价值	高	影子AI治理价值可量化（5.3节数据）；DBS案例显示统一护栏可将AI上线周期压缩超80%
引入风险与门槛	中	厂商整合期选型需组件化；多智能体治理工具尚不成熟；组织协同需行级统筹

评级结论：契合度与价值高、市场成熟度中等但整合趋势明确，维持"系统论证 / 论证层"定档，与现档一致；作为AI条目群的统一护栏应优先论证。

8.4 研判小结

AISP是AI技术栈中"不做就不能对客"的强制环节：威胁已列入Gartner顶级清单、监管要求明确、平台品类正快速整合、同业已有可验证的治理框架与量化成效。维持论证层定档，论证重点为能力缺口评估与内置/采购边界，建议与001智能体治理建设合并推进。

九、对策建议

9.1 论证方案与实施路线图

建议以6—9个月为期，分三阶段推进：

阶段	时间	核心任务	关键交付物	决策关口
第一步： 能力基线 评估	1— 2个 月	对照TRISM五层能力盘点行内现状（大模型平台内置护栏覆盖度、红队机制、运行时监测空白），以OWASP ASI十类风险为威胁清单做映射	能力缺口矩阵、AI资产初步台账	缺口矩阵评审，确定POC场景范围
第二步： 护栏与红 队试点	3— 6个 月	在001号智能体试点场景部署运行时护栏POC（输入注入检测、输出敏感信息拦截、动作越权告警三项硬指标），同步开展首轮AI红队演练；专业AISP产品与开源组合各选一路对比	POC测试报告、首轮红队发现清单、护栏策略迭代版本	POC效果评审，确定自建/外采/混合路径
第三步： 评审定档	7— 9个 月	形成AISP能力蓝图（与036评估基础设施的共建边界、与008零信任的身份衔接）、AI安全职责分工方案	AISP能力蓝图、三方分工方案、定档复评材料	提交定档复评

图3 AISP论证方案实施路线图（自制示意图）

9.2 能力建设优先级

能力项	价值	难度	依据
AI资产台账与影子AI发现	高	低	78%职场AI用户存在未经批准使用行为，无治理组织事故修复成本是有治理组织的2.5倍[15]
输入/输出护栏（智能体试点场景）	高	中低	Gartner三件套建议；监管底线[1,2]；ABS护栏手册9类护栏中输入输出过滤为基础层[18]
AI红队常态化机制	高	中	OWASP ASI基线落地；投产门禁化[1,16]
运行时行为监测与强制	中高	中高	TRiSM核心增量；依赖036观测管道[4]
多智能体治理工具	中	高	业界不成熟，跟踪为主，服务034号

9.3 效益测算参考区间

成本侧：平台许可或开源自建人力投入、护栏策略配置与迭代工时、AI红队团队（2—3人起步）。收益侧参考同业已披露数据，给出三档区间估算（非本行实测数据，作为论证阶段的参考基线，实际收益应在POC阶段以本行数据校准）：

收益类型	保守	中性	乐观	数据依据
AI项目上线周期压缩	缩短10%—20%	缩短30%—50%	缩短超50%（对标DBS 15个月→3个月，约80%）	DBS统一治理框架案例[19]
AI安全事件修复成本节约	节约10%—30%	节约50%左右	节约60%以上（无治理组织修复成本为有治理组织2.5倍）	Airia影子AI统计[15]
数据泄露风险规避	定性收益为主，暂不计入财务测算	以488万美元/次的行业平均数据泄露成本为参照估算边际规避价值	需结合本行历史事件基线测算	IBM/Ponemon行业均值，经Airia转引[15]
决策与内容合规审计工时节约	节约20%左右	节约30%—40%	节约50%以上（留痕自动化）	参照033号DIP同类治理层测算逻辑

回收期建议按12—24个月设定（较033号DIP更短，因AISP多数能力为监管强制底线投入，非纯效率驱动型投资，收益兑现更依赖风险规避而非直接营收）。

9.4 横向保障

- 协同：与001（智能体控制台）、036（评估观测底座）、008（智能体身份）三线统筹，AISP作为AI条目群统一护栏一次建设。
- 组织：明确安全条线牵头AI安全策略、科技承建平台、模型风险管理纳入验证职责的三方分工。
- 对年度研判报告的输入：以"AI场景护栏覆盖率、红队演练发现与修复闭环率、影子AI发现数"作为年度呈报口径。

十、结论与处置建议

- 维持储备库"论证层 / 系统论证"定档；本报告纳入研究成果库并同步台账与评估表。
- 建议AI资产台账与试点场景护栏作为先行动作即刻启动；论证与001智能体治理合并立项。
- 按季度跟踪：Gartner AI TRiSM市场指南更新与厂商并购动态、OWASP智能体安全测试指南、多智能体治理工具成熟度、国内银行业AISP治理机制披露进展。

十一、附录

11.1 名词术语表

术语	简释
AISP	AI Security Platform，人工智能安全平台，本报告主体技术
AI TRiSM	AI Trust, Risk and Security Management，Gartner提出的AI信任、风险与安全管理框架，AISP的方法论源头
提示注入（Prompt Injection）	攻击者通过构造恶意输入操纵大模型/智能体行为的攻击方式，2026年Gartner头部威胁之一
护栏（Guardrail）	对模型输入输出施加的实时过滤与控制机制，分输入护栏与输出护栏
红队（Red Team）	主动模拟攻击以发现AI系统安全漏洞的测试方法
影子AI（Shadow AI）	未经组织IT/安全部门审批而被使用的AI工具或应用
OWASP ASI	OWASP发布的智能体应用十大安全风险清单（《Top 10 for Agentic Applications》）
HITL	Human-in-the-loop，人工在环，指关键决策环节保留人工审核

11.2 数据来源与检索时间说明

原v1.2版7条信源信息采集截至2026年7月8日；本次深化新增信源14条，信息采集截至2026年8月17日。新增信源类型包括：Gartner/厂商官方发布（[8][9][10][11][12][13]）、行业市场研究机构报告（[14]）、企业安全博客与行业调研（[15]）、OWASP官方资源（[16]）、国家网络安全标准化技术委员会官方文件（[17]）、行业协会官方文件（[18]）、银行官方披露（[19]）、财经媒体转引的行业跟踪报告（[20]）、安全行业媒体方法论文章（[21]，注明为方法论演示而非实测案例）。全部新增数据均标注具体信源与发布时间，未使用未经核实的臆测数据；市场规模、并购金额等数字如信源存在披露差异，已在正文注明"据报道"“未正式披露确切金额”等限定表述。三、四章新增的技术背景、技术原理与演进脉络内容以既有信源与通用技术原理为基础组织撰写，其中AI TRiSM概念提出时间、NIST AI RMF表述两处标注为"背景知识、非本轮核实"，正式定稿前建议单独核实原文后补充引用编号。

参考文献

[1] Gartner. Gartner Identifies Four Critical Threats Requiring Urgent Improvements from Cybersecurity Leaders（提示注入与深伪列入；三件套建议）。新闻稿，2026-06-02. <https://www.gartner.com/en/newsroom/press-releases/2026-06-02-gartner-identifies-four-critical-threats-requiring-urgent-improvements-from-cybersecurity-leaders>

[2] The Elec. Gartner Identifies Deepfakes, Prompt Injection Among Top Cybersecurity Threats. 2026. <https://www.thelec.net/news/articleView.html?idxno=11160>

[3] Mindgard. Gartner AI TRiSM Market Guide（解读）。<https://mindgard.ai/blog/gartner-ai-trism-market-guide>

[4] F5. AI Security Through the Analyst Lens: Insights from Gartner, Forrester, and KuppingerCole. <https://www.f5.com/company/blog/ai-security-through-the-analyst-lens-insights-from-gartner-forrester-and-kuppingercole>

[5] arXiv 2604.08059. Governed Capability Evolution: Lifecycle-Time Compatibility Checking and Rollback for AI-Component-Based Systems. 2026. <https://arxiv.org/pdf/2604.08059>

- [6] arXiv 2603.25097. ElephantBroker: A Knowledge-Grounded Cognitive Runtime for Trustworthy AI Agents. 2026. <https://arxiv.org/pdf/2603.25097>
- [7] arXiv 2505.03574. LlamaFirewall: An Open Source Guardrail System for Building Secure AI Agents. 2025. <https://arxiv.org/pdf/2505.03574>
- [8] HiddenLayer. HiddenLayer Named in 2025 Gartner Market Guide for AI Trust, Risk and Security Management (AI TRiSM). 2025. <https://www.hiddenlayer.com/news/hiddenlayer-recognized-in-2025-gartner-market-guide-for-ai-trust-risk-and-security-management-ai-trism>
- [9] Palo Alto Networks. Palo Alto Networks Completes Acquisition of Protect AI. 2025-07-22. <https://www.paloaltonetworks.com/company/press/2025/palo-alto-networks-completes-acquisition-of-protect-ai>
- [10] Cisco. Robust Intelligence Is Now Part of Cisco / Fortifying the Future of Security for AI. 2024-08. <https://blogs.cisco.com/news/fortifying-the-future-of-security-for-ai-cisco-announces-intent-to-acquire-robust-intelligence>
- [11] Startupticker.ch. Check Point to Acquire Lakera. 2025. <https://www.startupticker.ch/en/news/check-point-to-acquire-lakera>
- [12] F5. F5 Completes Acquisition of CalypsoAI, Introduces F5 AI Guardrails and F5 AI Red Team. 2025-09-11. <https://www.f5.com/company/blog/what-are-ai-guardrails>
- [13] SentinelOne. SentinelOne to Acquire Prompt Security to Advance GenAI Security and Agent Security Strategy. 2025. <https://www.sentinelone.com/press/sentinelone-to-acquire-prompt-security-to-advance-genai-security/>
- [14] Fortune Business Insights. AI TRiSM Market Size, Share and Analysis, 2026-2034. <https://www.fortunebusinessinsights.com/ai-trism-market-115120>
- [15] Airia. Shadow AI Statistics: Key Data Points Every CISO Needs in 2026. <https://airia.com/blog/shadow-ai-statistics-key-data-points-every-ciso-needs-in-2026/>
- [16] OWASP. Top 10 for Agentic Applications for 2026. OWASP Gen AI Security Project. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [17] 全国网络安全标准化技术委员会. TC260-003 《生成式人工智能服务安全基本要求》. 2024-03. <https://www.tc260.org.cn/portal/article/2/20240301164054>
- [18] Association of Banks in Singapore (ABS) / MAS. Handbook on Generative AI Guardrails in Banking. 2025-05. <https://www.abs.org.sg/docs/library/handbook-on-generative-ai-guardrails-in-banking.pdf>
- [19] DBS Bank. Responsible AI in Banking: Gaining a Competitive Edge. <https://www.dbs.com/artificial-intelligence-machine-learning/artificial-intelligence/responsible-ai-in-banking-gaining-a-competitive-edge.html>
- [20] 中国银行业大模型应用跟踪报告（2026年）, 经财经媒体转引. <https://finance.sina.com.cn/wm/2026-04-17/doc-inhuvres2073569.shtml>
- [21] 安全内参. 面向AI智能体的红队测试实战：基于OWASP ASI 2026的金融场景攻防实践（方法论演示文章，非实测案例）. <https://www.secrss.com/articles/90244>

说明：本报告基于公开信源整理，未使用付费订阅原文；[20][21]为二手/方法论来源，关键数据建议以原始报告核验。原信息采集截至2026-07-06；2026-08-17深化（升v2.0）新增执行摘要、产业链生态位图谱、技术选型比选、

监管合规映射表、同业案例研究（原6.1-6.4）、风险register、效益测算区间、名词术语表、数据来源说明等章节，参考文献由7条扩充至21条；2026-08-17进一步深化（升v2.1）将原"技术全景与概念界定"一章拆分为"技术背景与基本原理"（新增问题背景、技术原理机制、演进脉络、技术局限四个维度）与"技术架构与生态定位"两章，后续章节相应顺延编号，参考文献与信源数量不变。